2026/2027

Fundamentos de Ciberseguridad

CIB

MOISÉS ALBERTO DOMÍNGUEZ CRUZ
IES LOS SAUCES – DAW2

Fundamentos de ciberseguridad

Ejercicio 1.1 2
1. Amenazas y vulnerabilidades informáticas. 2
2. Medidas de protección básicas. 12
3. Análisis de los incidentes de seguridad. 17
4. Herramientas y tecnologías de aplicación 19
5. Normativa y buenas prácticas de uso. 22
6. Auditoria de Seguridad 24
Webgrafía 25

Ejercicio 1.1

1. Amenazas y vulnerabilidades informáticas.

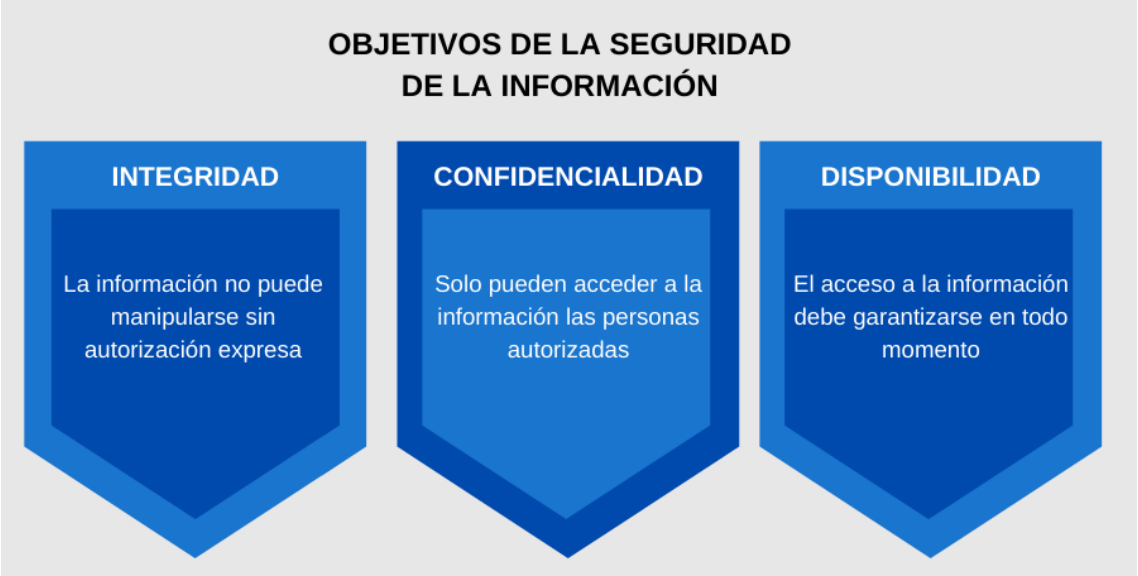
Conceptos básicos, diferencias entre amenazas activas y pasivas y su impacto.

Confidencialidad: Es la propiedad de la información que garantiza que este accesible únicamente a personal autorizado a dicha información.

Integridad: Datos o información exactos y fiables y que no han sido modificados accidentalmente o de manera intencional.

Disponibilidad: Asegura la fiabilidad y el acceso oportuno a los datos y recursos por parte de los individuos o personas autorizadas.

Diferencias → Cada uno protege un aspecto diferente del ciclo de vida de los datos.



Amenazas Pasivas

- Pérdida de privacidad y secreto industrial o comercial.
- Exposición de credenciales, datos financieros o información médica.
- Facilita la preparación de futuros ataques activos más dirigidos.

Ejemplos comunes: Sniffing, Análisis de tráfico...

Amenazas Activas

- Pérdida de integridad de los datos (información falsa o corrupta que lleva a malas decisiones operativas).
- Parálisis total o parcial de servicios críticos (pérdida económica inmediata por caída de plataformas).
- Daño reputacional severo y posibles sanciones regulatorias (por ejemplo, multas RGPD).

Ejemplos comunes: Suplantación de identidad, Modificación de mensajes, Ataques de denegación de servicio, Ransomware o inyección de malware...

Clasificación y características de las principales amenazas informáticas.

Tipos de malware

Adware: Muestra anuncios no deseados en la pantalla del ordenador o dispositivo móvil, redirige los resultados de las búsquedas a sitios web de publicidad y recopila los datos de los usuarios para venderlos a anunciantes sin su consentimiento.

Spyware: Se oculta en el dispositivo, controla tu actividad y roba información confidencial como datos financieros, información de cuentas, contraseñas y mucho más.

Ransomware: Diseñado para bloquear el acceso de los usuarios a su sistema o denegar el acceso a los datos hasta que se pague un rescate.

Troyanos: Se oculta como software legítimo con el fin de engañarte para que ejecutes software malicioso en tu equipo.

Gusanos: Son uno de los tipos de malware más comunes, se propagan en redes informáticas mediante la explotación de vulnerabilidades del sistema operativo.

Virus: Es un fragmento de código que se inserta en una aplicación y se ejecuta cuando esta se abre.

Keyloggers: Es un tipo de spyware que vigila la actividad del usuario.

Bots y botnets: Es un equipo infectado con malware que un hacker puede controlar de manera remota.

Técnicas de ingeniería social

Es una estrategia utilizada por personas o grupos para manipular y engañar a las personas con la intención de que revelen información delicada o lleven a cabo acciones que pongan en riesgo su seguridad.

Phishing



Los atacantes envían correos electrónicos, mensajes o enlaces engañosos a **sitios web que parecen legítimos** con el fin de confundir a los destinatarios para que hagan clic y revelen información delicada, como contraseñas, números de tarjetas de crédito o datos personales.

Phishing personalizado



Parecido al *phishing* pero **muy adaptado a cada persona**. Para resultar aún más convincentes, los atacantes personalizan los mensajes basándose en información concreta sobre el objetivo.

Baiting:



Los atacantes **ofrecen algo atractivo**, como descargas gratuitas de *software*, a cambio de información personal o acceso al sistema. Esta forma de actuar puede incluir archivos o enlaces infectados.

Pretexting:



Los atacantes elaboran una historia ficticia o un pretexto para obtener información. Esto implica a menudo **suplantar la identidad de alguien que inspira confianza**, como un colega o un representante de un banco.

Phishing de voz



Una forma de *phishing* que tiene lugar **mediante la comunicación por voz, habitualmente mediante una llamada telefónica**. Los atacantes se hacen pasar por entidades de confianza y convencen a las víctimas de que revelen información delicada.

Suplantación



Los atacantes **se hacen pasar por otra persona**, ya sea en línea o en persona, para ganar confianza y manipular al objetivo de forma que revele información confidencial o haga algo concreto.

Phishing en redes sociales



Los ataques **se dirigen principalmente a usuarios de redes sociales** y a menudo aprovechan un tema popular o una tendencia para crear mensajes engañosos, haciendo que parezcan pertinentes y fiables.

Programas de secuestro y extorsión



Los atacantes amenazan con **revelar información delicada** o perturbar los sistemas a menos que se pague un rescate. Infunden miedo para coaccionar a sus víctimas.

Ataques a la red

Acción deliberada para comprometer la seguridad, disponibilidad o integridad de los sistemas conectados.

Denegación de servicio (DoS/DDoS): Es un tipo de ciberataque en el que un actor malicioso tiene como objetivo que una máquina u otro dispositivo no esté disponible para los usuarios a los que va dirigido, interrumpiendo el funcionamiento normal del mismo.

Ataque de intermediario (MITM): Es un ciberataque en el que un hacker roba información confidencial espiando las comunicaciones entre dos objetivos en línea, como un usuario y una aplicación web.

Ataques a aplicaciones web

Intento por parte de agentes maliciosos de aprovechar las vulnerabilidades y debilidades de las aplicaciones web o móviles creadas durante el proceso de desarrollo de software, con el objetivo de interrumpir la actividad empresarial u obtener acceso al ecosistema de TI de una organización.

Inyección SQL: Es un método de infiltración de código intruso que se vale de una vulnerabilidad informática presente en una aplicación en el nivel de validación de las entradas para realizar operaciones sobre una base de datos.

Cross-site scripting: es un tipo de ataque informático que permite a un actor de amenazas ejecutar código malicioso en el navegador de otro usuario.

Clasificación de vulnerabilidades en sistemas, redes y aplicaciones.

Vulnerabilidades de sistema operativo

Permiten el acceso a atacantes que dañan los dispositivos donde está instalado.

Las páginas web pueden distribuir códigos maliciosos, de manera que, cuando un usuario las visita, se descarga automáticamente un archivo que infecta el dispositivo.

Vulnerabilidades de red

Se ubican en la infraestructura del hardware, en el software o en procesos organizacionales del sistema. Este tipo de vulnerabilidad informática puede ser física o no física:

- *Físicas:* como alojar el servidor en un lugar cuyas condiciones no son aptas y pueden dañarlo —por ejemplo, en un área poco ventilada, húmeda, con riesgo de inundaciones o incendios— o donde personas no autorizadas pueden acceder de forma fácil.
- *No físicas:* como un acceso inalámbrico mal protegido, cortafuegos mal configurados o un software obsoleto que no tiene los parches adecuados para nuevas amenazas.

Vulnerabilidades de aplicaciones web

Afectan al software de uso específico, especialmente en entornos web.

Inyección de código (Injection): Inserción de comandos maliciosos (como SQL) no filtrados por la aplicación.

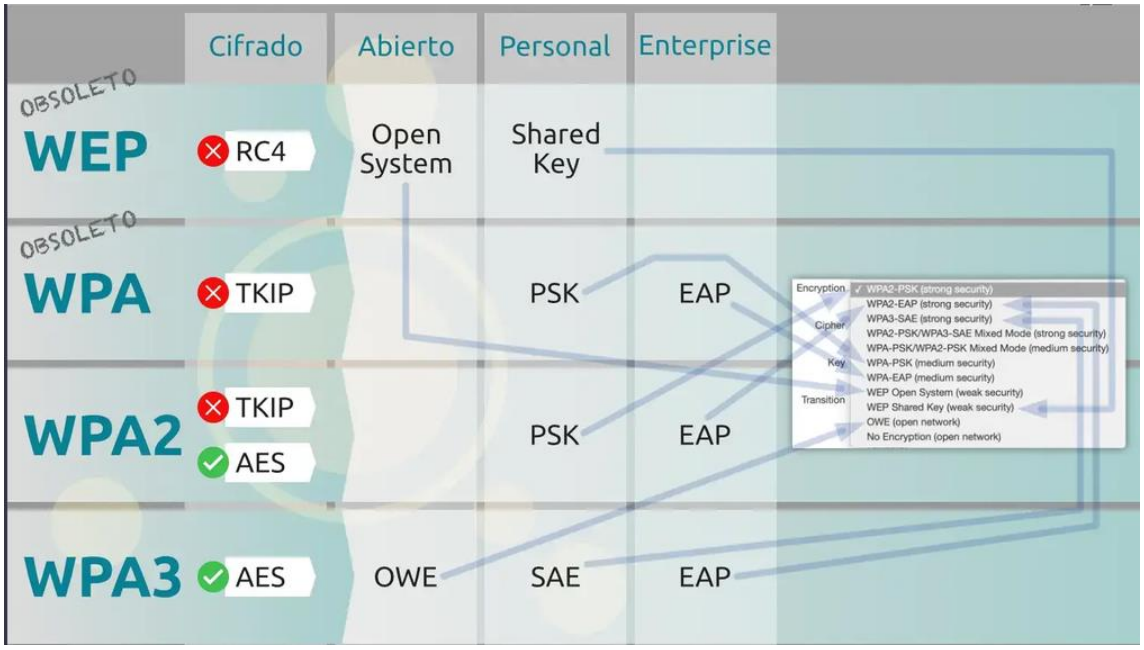
Control de acceso roto: Fallos que permiten a un usuario ver o hacer cosas sin la autorización debida.

Componentes vulnerables: Uso de librerías o dependencias de terceros desactualizadas.



Redes inalámbricas sin cifrar o con cifrados obsoletos.

Las redes inalámbricas sin cifrar o con protocolos antiguos como WEP exponen todo tu tráfico de internet a que cualquier intruso lo lea o robe en cuestión de minutos.



Relación entre amenazas y vulnerabilidades.

La relación entre amenaza y vulnerabilidad se basa en que la vulnerabilidad es la debilidad interna que permite que una amenaza externa o potencial cause un daño.

Amenaza: Un evento, agente o circunstancia externa o potencial que puede provocar un daño o ataque.

Vulnerabilidad: Un fallo, punto débil o característica propia de un sistema que lo hace susceptible a dicha amenaza.

Mecánica de explotación: identificación de vulnerabilidades por los atacantes.

Los atacantes identifican vulnerabilidades mediante análisis automatizados, investigaciones de seguridad y escaneos de red para encontrar fallos que luego puedan aprovechar.

Resumen de como DETECTAR y Explotar VULNERABILIDADES



Ejemplos prácticos de explotación: ransomware en sistemas desactualizados e inyección SQL.

Casos reales de ataques Exploit

A lo largo de los últimos años, los exploits han estado detrás de algunos de los ciberataques más sonados a nivel mundial. Estos casos muestran cómo una vulnerabilidad no corregida puede desencadenar consecuencias millonarias y afectar a miles de organizaciones.

- **WannaCry (2017)**

  Este ransomware se propagó utilizando el exploit EternalBlue, que aprovechaba una vulnerabilidad crítica en Windows. En pocos días afectó a hospitales, fábricas y empresas de todo el mundo, provocando pérdidas estimadas en más de 4.000 millones de dólares.

- **Equifax (2017)**

  Una de las mayores brechas de datos de la historia: más de 147 millones de registros personales quedaron expuestos debido a una vulnerabilidad no parcheada en Apache Struts. Los atacantes usaron un exploit conocido y ya corregido, pero la empresa no había aplicado la actualización.

- **Microsoft Exchange (2021)**

  Exploits de día cero permitieron a atacantes acceder a miles de servidores de correo corporativos en todo el mundo. El incidente derivó en robo masivo de datos y puertas traseras instaladas para acceso persistente.

- **Log4Shell (2021)**

  Una vulnerabilidad crítica en la librería Log4j, muy utilizada en aplicaciones Java, permitió la ejecución remota de código (RCE). Los exploits aparecieron en cuestión de horas y aún hoy siguen detectándose intentos de explotación.

- **SharePoint "ToolShell" (2025)**

  En 2025, varias campañas activas aprovecharon vulnerabilidades en servidores on-premises de Microsoft SharePoint (CVE-2025-49706 y CVE-2025-49704) para lograr acceso inicial y moverse lateralmente en redes corporativas.

Evaluación de las consecuencias de las amenazas y vulnerabilidades.

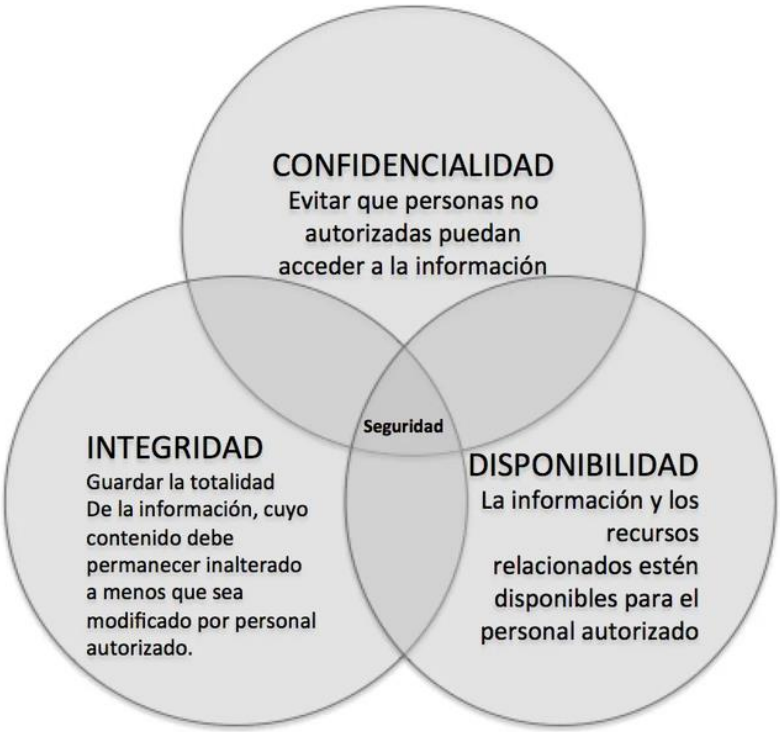
Pasos para Evaluar las Consecuencias

1. **Identificar los activos:** Reconocer qué se quiere proteger (datos, equipos, personas o infraestructura).
2. **Detectar amenazas y debilidades:** Listar los peligros posibles y las fallas de seguridad o de protección existentes.
3. **Calcular la probabilidad:** Estimar qué tan posible es que la amenaza logre explotar la vulnerabilidad.
4. **Medir el impacto:** Analizar la magnitud del daño si el evento sucede (escala de bajo a crítico o de 0 a 1).
5. **Priorizar el riesgo:** Combinar probabilidad e impacto para decidir qué problemas se deben solucionar primero.



Impacto sobre la confidencialidad, la integridad y la disponibilidad.

Determina el daño real que sufre una organización cuando un sistema o dato es atacado, robado o modificado.



Señales y síntomas de amenazas y vulnerabilidades activas.

Los principales signos y síntomas de que tu infraestructura o sistema está bajo un ataque activo o presenta fallos críticos se dividen en las siguientes categorías:

- **Lentitud extrema inexplicable:** Caídas drásticas en la velocidad del sistema, servidores o red sin un aumento real de usuarios legítimos.
- **Consumo de recursos al 100%:** Uso inusualmente alto de la CPU, memoria RAM o disco por procesos desconocidos o procesos legítimos duplicados.
- **Cuelgues y reinicios constantes:** Pantallazos azules, congelamientos o reinicios automáticos de servidores y equipos de trabajo.
- **Antivirus o firewall desactivados:** Programas de seguridad que se apagan solos o alertas de seguridad que desaparecen de los registros.
- **Modificaciones en archivos del sistema:** Archivos críticos modificados, eliminados o con permisos de acceso alterados sospechosamente.

- **Políticas de grupo cambiadas:** Alteraciones en las restricciones de red, firewalls internos o configuraciones de contraseñas sin autorización previa.
- **Bloqueos de cuentas masivos:** Múltiples usuarios bloqueados al mismo tiempo debido a intentos fallidos de inicio de sesión (síntoma de ataque de fuerza bruta).
- **Inicios de sesión anómalos:** Accesos detectados a altas horas de la noche, desde ubicaciones geográficas imposibles o desde dispositivos no registrados.
- **Nuevos usuarios administradores:** Aparición de cuentas con privilegios elevados que ningún departamento de TI ha creado.
- **Picos de tráfico saliente:** Grandes volúmenes de datos que salen de la red hacia servidores externos desconocidos (exfiltración de datos).
- **Conexiones a IPs maliciosas:** Dispositivos internos intentando comunicarse de forma repetida con direcciones IP o dominios catalogados como peligrosos.
- **Consultas DNS masivas:** Comportamiento inusual en las solicitudes de resolución de nombres, que a menudo indica comunicación con redes de bots (*botnets*).
- **Borrado de logs de auditoría:** Registros de eventos que aparecen vacíos o con saltos de tiempo inexplicables (los atacantes suelen borrar sus huellas).

2. Medidas de protección básicas.

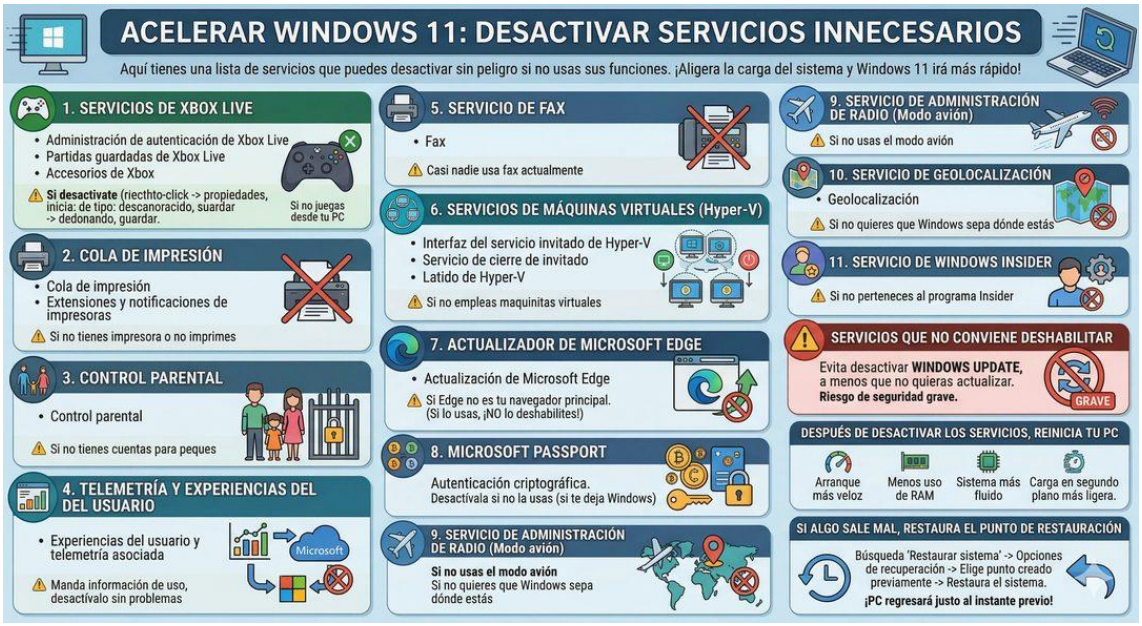
Conceptos básicos

Servicios innecesarios→ Procesos habilitados de fábrica que consumen recursos y abren puertos sin justificación operativa.

Actualizaciones→ Modificaciones de software destinadas a corregir errores funcionales y brechas de seguridad.

Vulnerabilidades conocidas→ Fallos documentados en bases de datos públicas.

Procedimientos para desactivar servicios innecesarios en sistemas operativos



Herramientas para gestionar actualizaciones y parches de seguridad

- NinjaOne Patch Management.
- ManageEngine Patch Manager Plus.
- SolarWinds Patch Manager.
- Ivanti Patch for Endpoint Manager.
- Automox.
- Patch My PC.
- PDQ Deploy.

(Fuente: https://blog.invgate.com/es/software-de-gestion-de-parches)

Gestión de contraseñas robustas

La gestión de contraseñas robustas es el conjunto de prácticas, políticas y tecnologías utilizadas para crear, almacenar, rotar y proteger las credenciales de acceso de los usuarios contra ataques de fuerza bruta, diccionario o ingeniería social.

Características de una contraseña segura

- Longitud adecuada: Mínimo de 12 a 16 caracteres. La longitud es el factor que más dificulta los ataques de fuerza bruta.
- Complejidad y variedad: Uso combinado de letras mayúsculas, minúsculas, números y caracteres especiales ($, @, %, etc.).
- Imprevisibilidad: Evitar palabras de diccionario, fechas de nacimiento, secuencias (123456) o patrones lógicos (qwerty).
- Uso de frases de contraseña (Passphrases): Frases largas compuestas por palabras aleatorias (ej. CaballoAzulVentanaGato!99), que son más fáciles de recordar para el usuario y matemáticamente muy difíciles de descifrar.

Políticas de gestión de contraseñas

- Prohibición de reutilización: Mantener un historial de contraseñas para evitar que el usuario vuelva a utilizar sus últimas 5 a 10 claves.
- Bloqueo de cuenta (Account Lockout): Bloquear temporalmente el acceso tras un número determinado de intentos fallidos (ej. 3 a 5 intentos) para mitigar ataques de fuerza bruta.
- Rotación de contraseñas: Aunque históricamente se exigía el cambio cada 90 días, estándares actuales como NIST recomiendan exigir el cambio solo si hay sospecha de compromiso, ya que la rotación forzada suele llevar a contraseñas más débiles (ej. Password1!, Password2!).
- Uso de gestores de contraseñas: Herramientas centralizadas y cifradas (como Bitwarden, 1Password o KeePass) que generan y almacenan claves únicas para cada servicio.

Métodos de autenticación alternativos: autenticación Multifactor (MFA)

- Aplicaciones autenticadoras: Programas en el móvil (como Microsoft Authenticator o Google Authenticator) que generan códigos temporales o avisos en pantalla.
- Mensajes SMS o llamadas: Códigos de un solo uso enviados al teléfono.
- Llaves de seguridad físicas: Dispositivos USB (como FIDO2) que se conectan al equipo.
- Datos biométricos: Lectura de huella o lectura de cara en el dispositivo.



Recursos multimedia:

- Video explicativo: ¿Qué es la Autenticación Multifactor (MFA)?

Control de accesos y permisos

El control de acceso es el proceso mediante el cual se restringe o se permite el uso de recursos específicos a usuarios o sistemas autenticados, basándose en un conjunto de políticas y reglas predefinidas.

- Principio de Menor Privilegio (PoLP): Otorgar a cada usuario o proceso únicamente los permisos estrictamente necesarios para realizar sus tareas, ni más ni menos.
- Necesidad de saber (Need-to-know): Incluso si un usuario tiene los privilegios técnicos para acceder a un recurso, no debe hacerlo a menos que sea necesario para su función actual.
- Separación de funciones: Dividir tareas críticas entre varios usuarios para que ninguna persona tenga control total sobre un proceso sensible, reduciendo el riesgo de fraude interno.

Gestión de roles y permisos en sistemas operativos

RBAC (Role-Based Access Control): Los permisos se asignan a roles (ej. "Administrador", "Auditor", "Usuario base") y los usuarios se asignan a esos roles, simplificando la gestión a gran escala.

- **Windows:** Utiliza NTFS para asignar permisos de lectura, escritura, modificación y control total a nivel de archivo/carpeta. A nivel de red corporativa, utiliza Active Directory (AD) mediante Grupos de Seguridad.

- **Linux/Unix:** Utiliza un sistema básico de permisos (Lectura r, Escritura w, Ejecución x) divididos en Usuario (Owner), Grupo (Group) y Otros (Others). Se gestionan con comandos como chmod y chown. Para un control más granular se utilizan las ACLs (Listas de Control de Acceso).

Configuración de accesos en redes:

VLANs (Redes de Área Local Virtuales): Segmentación lógica de la red para evitar que un departamento (ej. Invitados) acceda a los recursos de otro (ej. Finanzas).

VPNs y ZTNA (Zero Trust Network Access): Controles para usuarios externos. ZTNA asume que ninguna red es confiable y verifica la identidad y el estado del dispositivo en cada solicitud de acceso.

802.1X y NAC (Network Access Control): Autenticación requerida a nivel de puerto físico o Wi-Fi antes de que el dispositivo obtenga una IP y pueda comunicarse en la red.

Enlaces de interés:

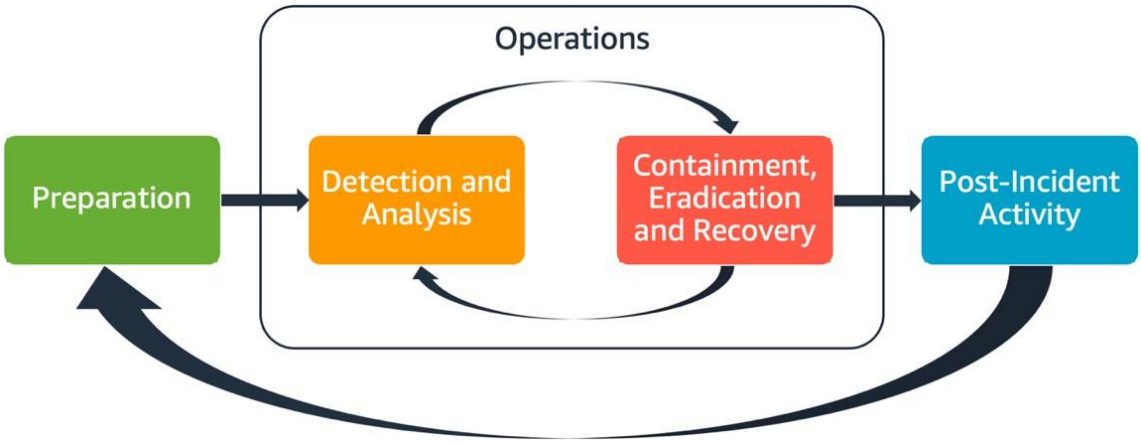
- Documentación de Microsoft sobre Control de Acceso
- Guía de administración de permisos en Linux

Implementación de reglas de firewall

Un firewall (cortafuegos) es un sistema de seguridad de red que monitoriza y controla el tráfico entrante y saliente basándose en reglas de seguridad predeterminadas. Establece una barrera entre redes confiables (internas) y redes no confiables (Internet).

3. Análisis de los incidentes de seguridad.

a) **Concepto y ciclo de vida:** Un incidente ocurre cuando una amenaza explota una vulnerabilidad, generando consecuencias negativas. Su gestión sigue el Ciclo de vida de un incidente: detección, análisis, contención, erradicación, recuperación y aprendizaje.



Proceso que sigue un equipo de seguridad para manejar un incidente:

- ***Detección:*** Identificar que ha ocurrido un incidente.
- ***Análisis:*** Determinar la causa y el alcance del incidente.
- ***Contención:*** Limitar el daño y evitar que se propague.
- ***Erradicación:*** Eliminar la amenaza de los sistemas afectados.
- ***Recuperación:*** Restaurar los sistemas y datos a un estado normal.
- ***Aprendizaje:*** Revisar el incidente para mejorar la seguridad y prevenir futuros problemas.

Enlace de interés:

- Guia oficial del NIST

b) Clasificación: Los incidentes se tipifican según su origen (internos o externos) y su magnitud (dirigidos o masivos). Para catalogarlos adecuadamente, se utilizan criterios como la naturaleza del ataque, su alcance y el objetivo final.

c) Evidencias de ataque: Los Indicadores de compromiso (IoC) son fragmentos de datos que confirman una intrusión. Se clasifican en IoCs basados en red (ej. IPs maliciosas), en sistema y en registros (ej. hashes de malware). Identificarlos permite descubrir las técnicas de ataque empleadas.

Enlace de Interés:

- Indicadores de compromiso

d) Prevención y defensa: Las Estrategias proactivas se anticipan al daño mediante la configuración de firewalls, sistemas de detección de intrusos (IDS/IPS) y una estricta gestión de contraseñas y accesos. Cada medida debe tener una justificación técnica clara.

Enlace de Interés:

- Estrategias proactivas

e) Evaluación de impacto: Toda solución defensiva debe analizarse midiendo la mitigación del riesgo frente a su viabilidad técnica y operativa. El análisis coste-beneficio garantiza que implementar una medida no sea más costoso que el activo que busca proteger.

f) Elaboración de informes: Es fundamental documentar todo el proceso utilizando herramientas y formatos estandarizados. Las buenas prácticas dicen que los hallazgos técnicos deben comunicarse de forma precisa y adaptada a la audiencia.

g) Investigación digital: El análisis forense aplica técnicas para recopilar evidencias en sistemas y redes, siendo crítica la preservación de la cadena de custodia para su validez legal. Este proceso debe regirse por principios éticos y de cumplimiento normativo, garantizando la privacidad y la confidencialidad.



Enlace de Interés:

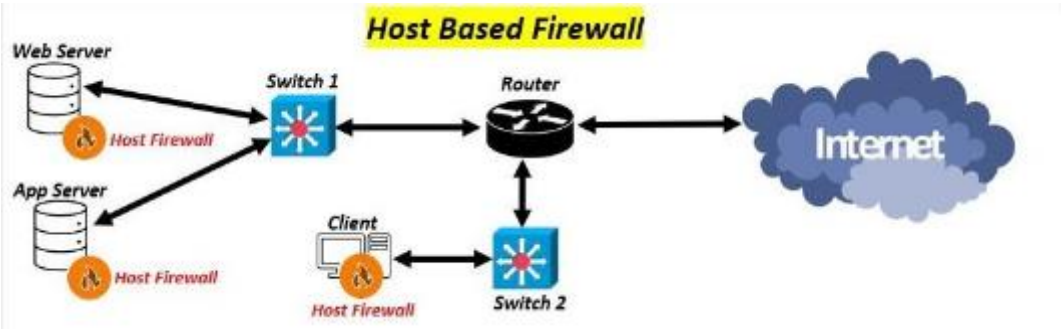
- Análisis forense

4.Herramientas y tecnologías de aplicación

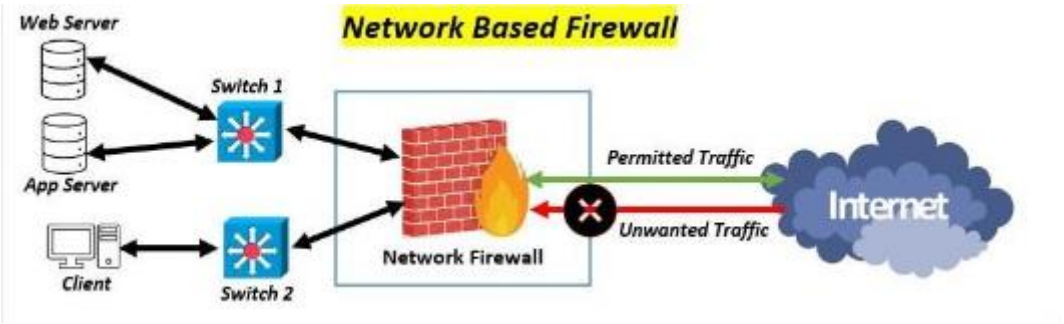
a) Introducción a las herramientas: Es fundamental conocer el concepto y tipos de herramientas de ciberseguridad, así como las funciones principales de los cortafuegos, sistemas IDS/IPS y software antivirus. De una configuración adecuada dependerá la correcta protección de los sistemas.

Contafuegos: basados en host y en red

Basados en host: Protegen un equipo específico, controlando el tráfico hacia y desde ese equipo.

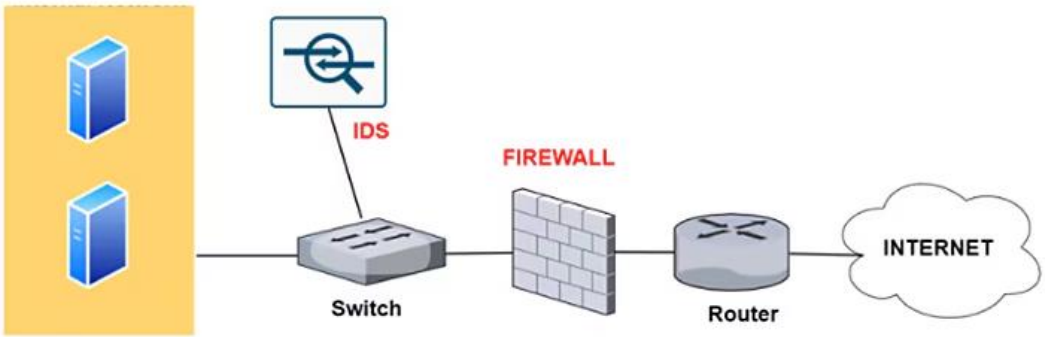


Basados en red: Protegen toda una red, filtrando el tráfico que entra y sale a nivel de red.

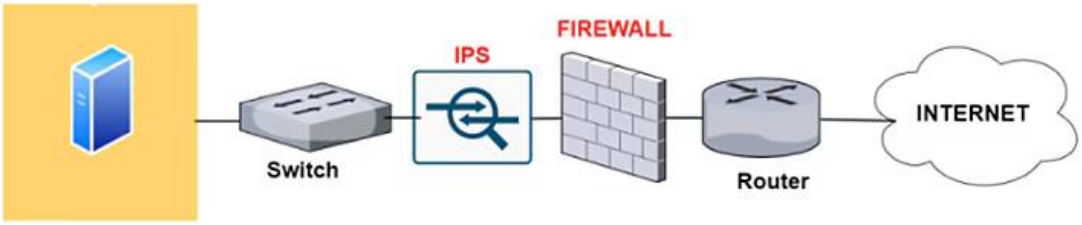


IDS/IPS

IDS: Sistema que detecta actividades sospechosas o intrusiones en una red o equipo.



IPS: Sistema de prevención de intrusiones que ayuda a identificar el tráfico malicioso y bloquea de manera proactiva el ingreso de dicho tráfico a su red.



Enlace de interés:

- IDS & IPS

Diferencias Cortafuegos vs IPS vs IDS

Parámetro	Cortafuegos	IPS	IDS
Propósito	Un dispositivo de seguridad de red que filtra el tráfico entrante y saliente basándose en reglas de seguridad predeterminadas.	Un dispositivo que inspecciona y previene las amenazas identificadas en tiempo real mediante el análisis del tráfico.	Un sistema que supervisa las actividades de la red o del sistema en busca de acciones maliciosas o violaciones de las políticas.
Operación	Filtra el tráfico basándose en reglas aplicadas a direcciones y números de puerto.	Examina el tráfico en busca de ataques en tiempo real e interviene para detenerlos en cuanto los detecta.	Observa el tráfico y busca patrones de ataque o anomalías, generando alertas.
Modo de configuración	Funciona en modo en línea o transparente en el límite de la red.	Normalmente en línea, situado después del cortafuegos dentro de la capa de red.	Generalmente funciona en modo de vigilancia, no en línea con el flujo de tráfico.
Trayectoria del tráfico	Debe ser la ruta principal del tráfico de la red.	Se coloca después del cortafuegos para examinar el tráfico filtrado.	Analiza el tráfico después de que haya atravesado el cortafuegos.
Colocación	Situado en el perímetro de la red como línea de defensa inicial.	Situado justo después de los cortafuegos, antes de la red interna.	Reside dentro de la red, normalmente después del IPS para un análisis más profundo del tráfico.
Respuesta al tráfico no autorizado	Bloquea o permite el tráfico en función de la evaluación de las reglas.	Impide activamente la progresión de las amenazas detectadas.	Emite alertas o alarmas al detectar actividades sospechosas.

Enlace de interés:

- Cortafuegos vs IPS vs IDS

Antivirus: Software diseñado para detectar, prevenir y eliminar programas maliciosos como virus, troyanos, spyware, ransomware, etc.



Enlace de interés:

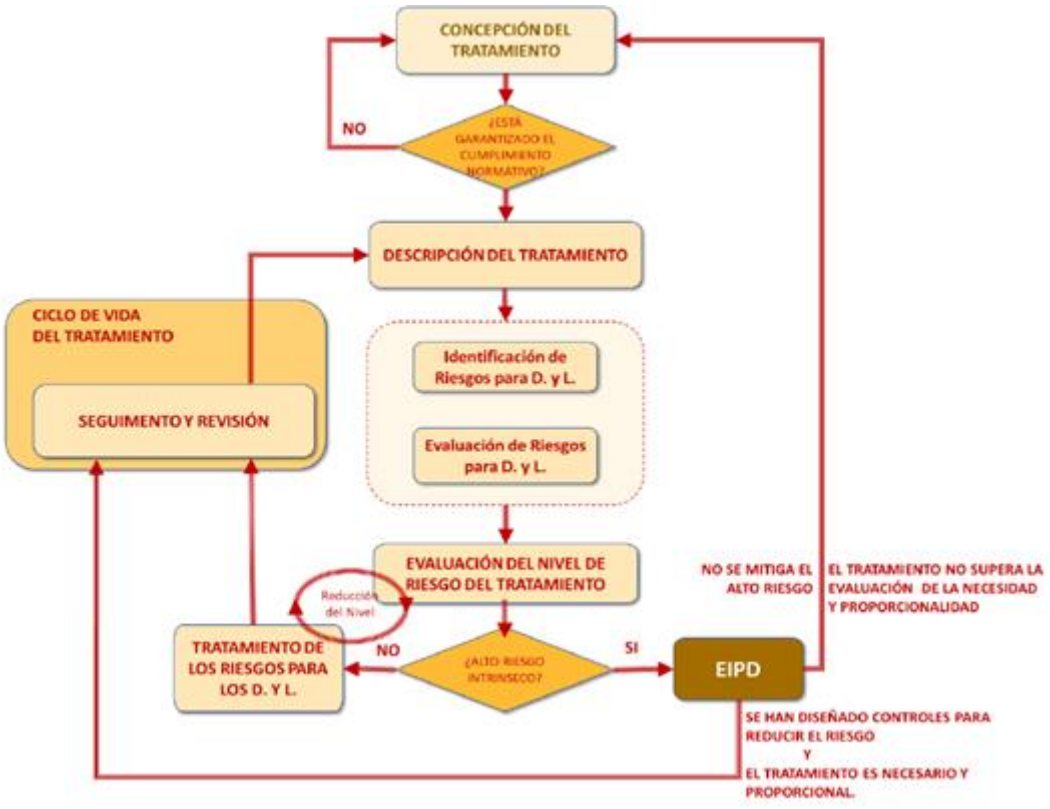
- Antivirus

5.Normativa y buenas prácticas de uso.

a) Principios de seguridad: La seguridad de la información persigue objetivos fundamentales basados en garantizar la confidencialidad, integridad y disponibilidad de los datos. Resulta de vital importancia mantener el cumplimiento normativo y aplicar buenas prácticas en todo entorno profesional.

b) Marcos reguladores: La ciberseguridad se rige por normativas y estándares tanto nacionales como internacionales. Destacan el Reglamento General de Protección de Datos (RGPD) para la privacidad, la norma ISO/IEC 27001 para sistemas de gestión, y el Esquema Nacional de Seguridad (ENS) en el ámbito español.

c) Gestión de la información: Las buenas prácticas exigen la clasificación adecuada de los datos sensibles y una estricta definición de las políticas de acceso. Asimismo, es crítico administrar adecuadamente todo el ciclo de vida de la información, desde su generación hasta su destrucción segura.



Enlaces de interés:

- Guia fuga de información INCIBE
- Control acceso INCIBE
- Gestión y evaluación del tratamiento de datos

d) Evaluación de medidas: Las medidas de seguridad deben validarse mediante herramientas de auditoría y análisis de casos en escenarios prácticos. Esto facilita un correcto Diagnóstico de fallos y la posterior formulación de Propuestas de mejora.

Enlaces de interés:

- Herramientas de auditoria INCIBE
- Guías de mejora INCIBE

e) Mejora continua y riesgos: Este proceso requiere identificar y evaluar constantemente las amenazas para desarrollar planes de acción efectivos. Para mantener la vigencia de la protección, es indispensable la revisión y actualización periódica de las políticas de seguridad.

f) Documentación y registro: Es obligatorio documentar la gestión elaborando políticas y procedimientos estructurados. Se debe mantener un Registro de incidencias utilizando formatos estándar para avalar el cumplimiento normativo, garantizando además una comunicación efectiva de las directrices a los usuarios.

Documentación Estructural

- **Políticas claras:** Definir los límites, responsabilidades y el marco normativo de la organización.
- **Procedimientos detallados:** Crear manuales paso a paso (SOP) para que el personal sepa exactamente cómo actuar ante cualquier situación.

Registro de Incidencias

- **Formatos estándar:** Utilizar plantillas homogéneas (ya sea en software especializado o formularios internos) que recojan datos críticos: fecha, descripción, impacto, acciones tomadas y responsable.
- **Evidencia auditable:** Este registro es la prueba objetiva ante auditorías externas o inspecciones de que la empresa reacciona y corrige sus fallos según la ley.

Comunicación a los Usuarios

- **Difusión efectiva:** No basta con redactar las políticas; es obligatorio capacitar a los usuarios y asegurar que las directrices sean accesibles, comprensibles y actualizadas periódicamente.

6. Auditoria de Seguridad

1. **Reconocimiento y Escaneo de Activos**
    a. **Uso de Nmap y NSE:** Empleo del escaner de redes en combinación con su motor de scripts (nse) para la exploración de infraestructura.
    b. **Inventario de activos empresariales:** Descubrimiento y catalogación de elementos críticos de la organización, abarcando direcciones Ips, puertos abiertos, URIs y Bases de datos.
    c. **Analisis de contactos:** Identificación y recopilación de contactos corporativos asociados a la superficie de ataque.

2. **Exposición Digital y Superficie de Ataque**
    a. **Seguridad de Marcas Web:** Realización de revisiones enfocadas en el análisis de seguridad de las marcas web de la entidad.
    b. **Evaluación de Exposición Digital:** Estudio del nivel de exposición digital general de la organización frente a amenazas externas e internas (MALOS / Empresa).
    c. **Inteligencia con Shodan:** Utilización de motores de búsqueda de dispositivos conectados como Shodan y sus tablas de hallazgos (Finding Table) para detectar activos expuestos en Internet.

3. **Marcos de Amenazas y Gestión de Vulnerabilidades**
    a. **Marco MITRE ATT&CK:** Aplicación de taxonomías de tácticas y técnicas basadas en el framework de MITRE ATT&CK para el análisis de vectores de ataque.
    b. **Correlación de Vulnerabilidades (NVD y CVE):** Consulta de la base de datos de vulnerabilidades NVD para la identificación y gestión de fallos de seguridad mediante sus códigos CVE.

4. **Simulación y Práctica Ofensiva**
    a. **Simulación de Ransomware en Vivo:** Análisis de escenarios de ataques avanzados y simulación de incidentes mediante ransomware live.
    b. **Laboratorios Prácticos:** Incorporación de plataformas de entrenamiento y hacking ético como Hack The Box para el desarrollo de competencias técnicas.

5. **Gestión y Documentación**
    a. **Informes de Tareas:** Elaboración de reportes de actividad orientados al registro y seguimiento de los procedimientos ejecutados (Informe Tareas).

Webgrafía

1. Conceptos Básicos de Ciberseguridad

- Confidencialidad (Wikipedia)
- Integridad Informática (Protección Datos LOPD)
- Disponibilidad en Seguridad Informática (UNIR)
- La disponibilidad como eje de la ciberseguridad industrial (Becolve)

2. Amenazas, Malware y Tipos de Ataques

- Qué es el Sniffing y cómo evitarlo (Red Seguridad)
- Análisis de tráfico (Wikipedia)
- Definición de Spoofing (Kaspersky)
- Ataques de Denegación de Servicio - DoS (Cloudflare)
- Qué es el Ransomware (IBM)
- Tipos de Malware (Kaspersky)
- Ingeniería Social (Consejo Europeo)
- Ataques a Aplicaciones Web (Akamai)
- Qué es un Exploit en ciberseguridad (Inforges)

3. Vulnerabilidades y Análisis de Riesgos

- Tipos de vulnerabilidad informática (LinkedIn)
- Diferencias entre amenazas y vulnerabilidades (OpenWebinars)
- Vulnerabilidades, amenazas y ataques (CAIB)
- Evaluación de Vulnerabilidades (SentinelOne)
- Análisis de Riesgo en 5 pasos (LinkedIn)
- Diferencias entre amenazas, vulnerabilidades y riesgos (Sectigo)

4. Medidas de Protección y Buenas Prácticas

- Cifrado Wi-Fi y Windows 11 (Banda Ancha)
- Configuración segura de activos y software (ISC2)
- Infografía: Crea tu contraseña segura (INCIBE)
- Software de gestión de parches (Invgate)
- Documentación de Microsoft sobre Control de Acceso
- Guía de administración de permisos en Linux (RedHat)

5. Análisis y Gestión de Incidentes de Seguridad

- Alertas Tempranas e Incidentes de Seguridad (INCIBE-CERT)
- Guía oficial de Gestión de Incidentes de Seguridad Informática (NIST SP 800-61r2)
- Indicadores de compromiso - IoC (INCIBE-CERT)
- Estrategias proactivas "Shields Up" (CISA)
- Análisis Forense Digital y Respuesta a Incidentes (SANS Institute)

6. Herramientas y Tecnologías de Aplicación

- ¿Qué es un cortafuegos? (Cisco)
- Cortafuegos basados en red y en host (Palo Alto Networks)
- Diferencias entre Sistemas IDS e IPS (Fortinet)
- Definición de Sistemas de Detección de Intrusiones - IDS/IPS (Kaspersky)
- Concienciación sobre Antivirus (INCIBE)
- Software Antivirus y Antimalware (Malwarebytes)

7. Normativa, Cumplimiento y Gestión de la Información

- Reglamento General de Protección de Datos - RGPD (AEPD)
- Norma ISO/IEC 27001 para la seguridad de la información (ISO)
- Esquema Nacional de Seguridad - ENS (CCN-CERT)
- Guía sobre el ciclo de vida de los datos (AEPD)
- Guía de fuga de información y datos sensibles (INCIBE)
- Gestión del control de acceso (INCIBE)
- Gestión y evaluación del tratamiento de datos (AEPD)
- Herramientas de auditoría y diagnóstico (INCIBE)
- Guías y propuestas de mejora (INCIBE)
- Notificaciones y registro de incidencias (INCIBE-CERT)

8. Recursos Multimedia y Redes Sociales

- Vídeo: Claves para proteger tu software / OWASP (YouTube)
- Vídeo: Hacking Paso a Paso desde Cero (YouTube)
- Vídeo explicativo: ¿Qué es la Autenticación Multifactor - MFA? (YouTube)
- Publicación sobre ciberseguridad en redes sociales (X / Twitter)